axis-communications-firmware-threat-brief

Axis Communications Firmware Attack Surface & Detection Brief

Scope: *Superseded in part — see "Extracted-firmware findings — AXIS OS 12.11.119.4 access controllers" at the end of this brief, which is based on five extracted rootfs images.* The research below predates that acquisition: at the time of writing it was CVE and public-advisory research only — firmware had not yet been acquired or extracted. Axis's `pub_soft` directory listing is publicly browsable (e.g. `axis.com/ftp/pub_soft/PACS/<model>/latest/` shows `A1001.bin`, `A1601.bin`, `A1610.bin`), but the actual firmware download redirects to MyAxis authentication — a Curity identity provider — and returns a ~6 KB HTML login page instead of the binary (verified 2026-09-28). No direct binary examination; no extracted rootfs, no file hashes, no service enumeration. Every finding below comes from public vulnerability disclosures (NVD, CISA ICS advisories, Axis's own PSIRT registry at help.axis.com), third-party research write-ups, and product documentation. Where a specific claim could not be confirmed with a real citation, that is stated explicitly rather than filled in.

Purdue layer mapping: Axis network cameras and video encoders are field devices that terminate the process at the sensor layer (image capture), and the A1001 is a field device that terminates it at the actuator layer (door-strike/lock relay driven over OSDP) — the same *role* (direct physical-world interface, no intervening controller) that Purdue L1 describes for PLCs, RTUs, and relays. However, purdue-l1-basic-controllers-brief.md is explicitly scoped to **process-loop controllers** (chassis/compact PLCs, DCS controllers, RTUs, protective relays, VFDs) across six industrial-automation vendors, and as of this writing it contains no physical-security or building-automation device class. Cameras and access controllers are therefore **L1-equivalent by role but not currently in that brief's vendor scope** — flagged here the same way that brief flags Eaton's UPS MCU as "L0/L1-adjacent, not strictly L1, included for completeness." The management-plane software that administers Axis devices — **AXIS Camera Station / Camera Station Pro / Device Manager**, Windows services that brokers credentials, firmware pushes, and video archive access for the whole camera estate — sits at **Purdue L3 (Site Operations)**, the same tier as the Windows-side agents described in purdue-l3-site-operations-brief.md (that brief's Group D, Windows-side power-mgmt agents, is the closest existing analog: a Windows management service that brokers between an admin host and a fleet of embedded field devices).

Architecture / product grouping

Class	Purdue layer	Products	Stack	Status
A. Network Cameras	L1-equivalent field device (not yet in L1 brief scope)	Fixed/PTZ/bullet/dome IP cameras running AXIS OS (e.g. A1601/A1610/A8004-V/M/P/Q-series)	Embedded Linux (AXIS OS) on ARM/MIPS SoC; VAPIX HTTP(S) API; RTSP/554; ONVIF	**Staged, not acquired** — `firmware-staging/Axis/Camera/Network-Cameras/raw/`
B. Video Encoders	L1-equivalent field device	Analog-to-IP video encoders on the same AXIS OS base	Same AXIS OS firmware family as cameras	**Staged, not acquired** — `firmware-staging/Axis/Encoder/Video-Encoders/raw/`
C. ACAP Application Layer	Cross-cutting (runs atop A/B)	AXIS Camera Application Platform (ACAP) third-party apps, packaged as `.eap`	`.eap` = gzip-compressed tar container, installed via VAPIX; apps can request D-Bus / system access	**Staged, not acquired** — `firmware-staging/Axis/Camera/ACAP-Applications/raw/`. Separate attack surface from camera firmware itself — a signed-firmware device can still run an attacker-supplied application if unsigned-ACAP install is enabled.

Class	Purdue layer	Products	Stack	Status
D. A1001 Access Control Door Controller	L1-equivalent field device	AXIS A1001 Network Door Controller	Embedded Linux; `pacsiod` daemon handles OSDP (RS-485) to door readers; VAPIX/web management	**Staged, not acquired** — `firmware-staging/Axis/Access-Control/A1001/raw/`
E. Camera Station / Device Manager (VMS + fleet mgmt)	Purdue L3 (Site Operations)	AXIS Camera Station, Camera Station Pro, AXIS Device Manager	Windows .NET services; client-server protocol to manage/view the camera + A1001 fleet	Windows-side software, not embedded firmware — research only, not staged for extraction in this project

Group A/B — Network Cameras & Video Encoders (AXIS OS / VAPIX)

Direct attack surface (per public advisories, not verified against an extracted rootfs): the VAPIX HTTP(S) management API (`*.cgi` endpoints), RTSP/554 streaming, ONVIF, and — when enabled — the ACAP application-install path. Several VAPIX CGI endpoints have had real, Axis-confirmed command-injection and privilege-escalation findings; the pattern recurs across years and camera families, which suggests the VAPIX CGI surface as a whole, not one endpoint, is the systemic risk.

Confirmed CVEs:

CVE	CVSS	Product	Vector
CVE-2025-0324	**9.4 Critical**	AXIS OS, VAPIX Device Configuration framework	Privilege escalation; fixed in AXIS OS 12.3.33
CVE-2025-0358	8.8 High	AXIS OS, VAPIX Device Configuration framework	Lower-privileged user → administrator privileges; fixed in 12.4.0
CVE-2025-0360	7.8 High	AXIS OS, VAPIX Device Configuration framework	Incorrect user-privilege-level assignment; fixed in 12.2.41
CVE-2025-11142	7.1 High	AXIS OS, VAPIX `mediaclip.cgi`	Insufficient input validation → possible RCE; fixed in 12.7.53
CVE-2026-4757	7.2 High	AXIS OS, VAPIX API parameter	Improper input validation → code execution / possible privilege escalation; fixed in 12.11.44
CVE-2023-5677	Axis: 6.3 Medium / NVD: 8.8 High (sources disagree)	AXIS OS, VAPIX `tcptest.cgi`	OS command injection (CWE-78/94); requires operator- or admin-privileged service account; affects AXIS OS 5.51/6.50 branches and LTS 2020/2022 lines per CERTFR-2024-AVI-0095
CVE-2024-8160	3.8 Low (`CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:L/A:L`)	AXIS OS, VAPIX `ftptest.cgi`	Insufficient input validation → command injection, file transfer to/from device; requires admin-privileged service account; affected 10.9.0–<10.12.257 and 12.0.0–<12.1.21 (11.x unaffected)
CVE-2024-47259	7.1 High (one source lists CVSS 3.5 — scores disagree across aggregators)	AXIS OS, VAPIX `dynamicoverlay.cgi`	Insufficient input validation → file upload / resource exhaustion

CVE	CVSS	Product	Vector
CVE-2018-10661	9.8 Critical, EPSS ~86.5%, **listed in VulnCheck KEV**	~390 legacy Axis camera models (incl. P1325-Z, Q1910-E, A8004-V firmware <1.65.2)	Authorization bypass reaching `.srv` → `parhand` handler in `/bin/ssid` without authentication; chains with CVE-2018-10660 (shell command injection as root) and CVE-2018-10662 (unrestricted D-Bus) for full remote root; VDOO 2018 disclosure; public Exploit-DB PoC (EDB-45100) and Metasploit module exist

Top attack vector (MITRE ATT&CK ICS): T0866 Exploitation of Remote Services against the VAPIX CGI surface, frequently chained with T0890 Exploitation for Privilege Escalation — the 2025 Device Configuration framework cluster (CVE-2025-0324/0358/0360) is exactly this pattern: initial low-privilege VAPIX access escalated to administrator. T0812 Default Credentials remains relevant given the 2018 VDOO-era finding that many deployed units still ran unauthenticated-reachable management paths years after patches shipped.

Group C — ACAP Application Layer (`.eap` packages)

Attack surface: `.eap` files are gzip-compressed tar containers installed through the VAPIX application-management API — a distinct product line from camera firmware itself, and a persistence/code-execution path that survives independently of the AXIS OS version. Tenable's 2018 research (confirmed via a Rapid7 Metasploit module, `axis_app_install`) found the platform did not validate that an installed application came from a trusted source; at the time Axis had no vendor-supplied fix, with the stated mitigation being network segmentation. Newer ACAP CVEs still follow the same precondition pattern: the device must be configured to allow unsigned ACAP installs, and an attacker (or a tricked user) must install a malicious application.

Confirmed CVEs:

CVE	CVSS	Vector
CVE-2025-0359	8.5 High	ACAP Application framework lets installed applications reach restricted D-Bus methods; fixed in AXIS OS 12.2.52
CVE-2025-5454	~6.4–6.7 Medium (sources disagree)	Insufficient input validation in an ACAP configuration file → path traversal → privilege escalation; requires unsigned-ACAP installs enabled + malicious app install
CVE-2025-5718	6.8 Medium	Symlink attack against the ACAP Application framework → privilege escalation; same precondition pattern
CVE-2026-0802	NVD: 6.0 Medium / other aggregators: 7.3 High (vector disagreement — `PR:H` vs `PR:L`)	ACAP configuration-file command injection → privilege escalation; affects AXIS OS 12.0.0–<12.9.33
Tenable 2018 — AXIS Camera App Malicious Package Distribution Weakness	No CVE assigned	No source-trust validation on ACAP package install; historical finding, status against current AXIS OS unverified in this research pass

Top attack vector (MITRE ATT&CK ICS): T0859 Valid Accounts (to reach the VAPIX app-install endpoint) chained with T0890 Exploitation for Privilege Escalation via a malicious `.eap`. This is a software-supply-chain-adjacent path distinct from camera-firmware CVEs — it persists across firmware upgrades if the installed ACAP app itself isn't removed.

Group D — A1001 Network Door Controller (physical access control)

Direct attack surface: `pacsiod`, the daemon handling OSDP (RS-485) communication to door readers, plus VAPIX/web management. The A1001 is specifically named in this project's staged-firmware tree and is the one product line in this brief

where the attack requires **local physical access** rather than network reach.

Confirmed CVEs/advisories:

CVE / Advisory	CVSS	Vector
CVE-2023-21406	7.1 High (Axis) / 8.8 (Recorded Future — sources disagree)	Heap-based buffer overflow in `pacsiod`'s OSDP message parser — appending invalid data writes outside the heap-allocated buffer, usable for arbitrary code execution; affects AXIS A1001 firmware ≤1.65.4; requires physical access to the RS-485 twisted-pair cable at the rear of a door reader; discovered by OTORIO (Ariel Harush, Roy Hodir); CISA published ICSA-23-206-01 (25 July 2023); fixed via Axis firmware update that hardens the OSDP parser
Advisory ACV-147453 (Jan 2019)	Not stated as a CVSS/CVE in sources found	A1001 flaw exploitable without authentication; fixed in firmware 1.65.2 or later. **No public CVE number was found for this advisory in this research pass** — it predates Axis becoming a CVE Numbering Authority (April 2021), when Axis used internal ACV identifiers instead.

OTORIO's research also noted that an attacker with this level of physical access could tamper with the controller's logs to hide activity — relevant for any detection plan built around the A1001's own audit trail (see logging matrix below).

Top attack vector (MITRE ATT&CK ICS): T0836 Modify Parameter via the OSDP heap overflow — an attacker who reaches the RS-485 bus can corrupt the daemon handling door-state logic. Given physical proximity is already required, this chains naturally with T0847 Replication Through Removable Media-style physical-access tradecraft rather than a remote network vector.

Group E — Camera Station / Device Manager (fleet management, Purdue L3)

Confirmed CVEs — CISA ICSA-25-352-08, published 2025-12-18, reported by Claroty Team82 (Noam Moshe):

CVE	CVSS v3.1	Product	Vector
CVE-2025-30023	**9.0 Critical**	Camera Station Pro <6.9, Camera Station <5.58, Device Manager <5.32	Deserialization of untrusted data (CWE-502) in the client-server communication protocol → authenticated RCE
CVE-2025-30024	6.8 Medium	Device Manager <5.32	Improper certificate validation (CWE-295) → man-in-the-middle
CVE-2025-30025	5.2 Medium	Camera Station Pro <6.8, Camera Station 5.x (all), Device Manager <5.32	Deserialization of untrusted data in server-process↔service-control protocol → local privilege escalation
CVE-2025-30026	6.1 Medium	Camera Station Pro <6.9, Camera Station <5.58	Authentication bypass using an alternate path/channel (CWE-288)

No known public exploitation of this cluster has been reported as of the advisory's publication. All four are fixed by upgrading to Camera Station Pro ≥6.9, Camera Station ≥5.58, Device Manager ≥5.32.

Top attack vector (MITRE ATT&CK ICS): T0830 Man in the Middle via CVE-2025-30024 to intercept/tamper fleet management traffic, chained with T0859 Valid Accounts and the CVE-2025-30023 deserialization RCE for full compromise of whatever host administers the camera/A1001 fleet — the single highest-value pivot point described in this brief, since that host holds credentials and firmware-push rights for every Axis device it manages.

Logging / detection matrix

Ordered by detection value for what is actually monitorable on Axis devices without an extracted firmware baseline:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	**VAPIX access log / reverse proxy or network IDS**	Repeated calls to `*.cgi` endpoints with known-vulnerable names (`ftptest.cgi`, `tcptest.cgi`, `dynamicoverlay.cgi`, `mediaclip.cgi`) from non-admin source IPs, or any call to these endpoints outside the camera's own management VLAN	Exploitation attempts against the confirmed VAPIX CGI command-injection cluster (CVE-2023-5677, CVE-2024-8160, CVE-2024-47259, CVE-2025-11142)	T0866 Exploitation of Remote Services
2	**Network IDS (Suricata/Zeek)**	RTSP/554 session establishment from a source not on the VMS/NVR allow-list; anomalous RTSP `DESCRIBE` / `SETUP` volume per device	Unauthorized stream pull / reconnaissance of the camera feed	T0866 Exploitation of Remote Services
3	**ACAP application-install events (VAPIX app-management log, where logged)**	Any `.eap` install, especially with unsigned-application install enabled	Malicious ACAP install (the CVE-2025-0359 / CVE-2025-5454 / CVE-2025-5718 / CVE-2026-0802 class, plus the 2018 Tenable finding)	T0890 Exploitation for Privilege Escalation
4	**Firmware-update events (VAPIX / syslog, where forwarded)**	`firmware.upgrade.*` outside a declared maintenance window, or upgrade initiated from a non-management-host IP	Firmware tamper / unauthorized downgrade (downgrade can reintroduce a patched CVE)	T0857 System Firmware
5	**A1001 OSDP/door event log**	`pacsiod` restart/crash correlated with physical maintenance-window absence; unexplained door-state or log gaps	OSDP parser exploitation (CVE-2023-21406) or the log-tampering behavior OTORIO flagged	T0836 Modify Parameter
6	**Authentication log (VAPIX / Camera Station / Device Manager)**	`login.failure` → `login.success` pattern; privilege-level change on a service account	Credential brute force or the Device Configuration framework privilege-escalation cluster (CVE-2025-0324/0358/0360)	T0812 Default Credentials
7	**Network IDS / TLS inspection on the Camera Station↔camera channel**	Certificate validation failures or downgraded/unexpected cert chain on the Device Manager↔device channel	CVE-2025-30024 man-in-the-middle exploitation	T0830 Man in the Middle
8	**Sysmon / EDR on the Camera Station or Device Manager host**	Deserialization-triggering network input followed by unexpected child process from the Camera Station/Device Manager service	CVE-2025-30023 RCE exploitation on the fleet-management host	T0890 Exploitation for Privilege Escalation

Secondary:

- Firewall: Axis cameras/A1001 units should never originate outbound connections to non-RFC1918 destinations; egress from the camera VLAN to the internet is itself an anomaly worth alerting on.
- VAPIX supports a device event/action-rule log on many models — enable it and forward "Applications," "System," and "Device access" categories to the SIEM where the specific camera model supports it; coverage varies by AXIS OS version and was not verified against any extracted firmware in this pass.
- Vendor feed: subscribe to the Axis security-advisory registry (CVE-numbered since Axis became a CNA in April 2021) for patch-window prioritization — the registry shows active, frequent disclosure (multiple High/Critical AXIS OS findings every few months through 2026).

Specific concerns for this dataset

1. **233 devices makes Axis Communications a top-tier OT vendor by count in the ARNG's 5,723-device nationwide OT & Building Systems census** (OUI string "Axis Communications AB," ForeScout + Dragos derived). That places it ahead of — or comparable to — several of the process-control vendors that already have detailed firmware briefs in this project (Rockwell, SEL, Siemens), none of which have anywhere near that device count in this specific inventory. The existing 14 briefs were written against a process-control-vendor assumption that does not match this census's actual composition, which skews toward building-automation and physical-security hardware.

2. **No binary has been examined for any of these 233 devices.** Every CVE above is a public disclosure; none have been confirmed against the firmware version(s) actually running on this census's Axis population, because the model/firmware-version field doesn't exist in the OUI-derived census and the firmware itself is gated behind MyAxis authentication. Treat every CVE in this brief as "possibly applicable, not confirmed applicable" until specific models and firmware versions are obtained (either through a MyAxis account or direct extraction from a sample device).

3. **The VAPIX CGI command-injection pattern has recurred across multiple, unrelated endpoints over multiple years** (`tcptest.cgi` in 2023, `ftptest.cgi` and `dynamicoverlay.cgi` in 2024, `mediaclip.cgi` in 2025) — this strongly suggests the vulnerability class (insufficient input validation in service-account-gated diagnostic CGI scripts) is systemic to how Axis implements these utility endpoints, not isolated to any one. Any VAPIX CGI endpoint not explicitly confirmed patched should be assumed to be a candidate for the same bug class.

4. **The A1001 is the one device class here where the realistic attacker model is physical, not remote** — RS-485 access at the reader, not network access to the controller. In a facility-protection context (which is exactly ARNG OTSDP's domain), that changes the mitigation priority from "patch and firewall" to "physically secure the reader-to-controller cable run and tamper-detect the door hardware," which is a different conversation than every other vendor brief in this project has had to have.

5. **ACAP (`.eap`) is a persistence mechanism independent of AXIS OS patch level.** A device fully patched against every VAPIX CVE above can still be running a malicious or vulnerable ACAP application if unsigned-app install was ever enabled and not subsequently audited. This is worth a specific question in any Axis device review: "is unsigned ACAP install enabled, and what applications are currently installed?" — a question the OUI-derived census cannot answer on its own.

Sources

- CISA ICS Advisory ICSA-25-352-08 — Axis Communications Camera Station Pro, Camera Station, Device Manager
- CISA ICS Advisory ICSA-23-206-01 — Axis A1001 Network Door Controller (CVE-2023-21406)
- Axis security-advisory registry (help.axis.com) — CVE-numbered AXIS OS / VAPIX / ACAP / Camera Station / Device Manager advisories
- Axis vulnerability management policy
- Axis PSIRT advisory PDF — CVE-2024-8160 (ftptest.cgi)
- Axis advisory ACV-147453 — A1001 (Jan 2019, pre-CNA)
- CVE-2023-5677 record — tcptest.cgi (CIRCL CVE Premium, mirrors CERTFR-2024-AVI-0095)
- CVE-2024-47259 record — dynamicoverlay.cgi
- CVE-2026-0802 record — ACAP config-file command injection
- CVE-2025-5454 record — ACAP path traversal
- hackread — AXIS A1001 Network Door Controller Flaw Exposes Secure Facilities (CVE-2023-21406 detail)
- notcve.org — CVE-2018-10661 detail (auth bypass chain)
- Security Affairs — Hacking more than 400 Axis camera models by chaining 3 flaws (CVE-2018-10660/10661/10662)
- Tenable Research Advisory — AXIS Camera App Malicious Package Distribution Weakness
- Rapid7 Metasploit module — axis_app_install (ACAP .eap upload/execute)
- MITRE ATT&CK for ICS — T0866 Exploitation of Remote Services
- MITRE ATT&CK for ICS — T0890 Exploitation for Privilege Escalation
- MITRE ATT&CK for ICS — T0830 Man in the Middle
- MITRE ATT&CK for ICS — T0836 Modify Parameter
- MITRE ATT&CK for ICS — T0857 System Firmware
- MITRE ATT&CK for ICS — T0812 Default Credentials
- MITRE ATT&CK for ICS — T0847 Replication Through Removable Media
- MITRE ATT&CK for ICS — TA0106 (Valid Accounts tactic reference used cross-vendor in this project)
- purdue-l1-basic-controllers-brief.md — cross-vendor L1 reference (process-loop controllers; Axis not currently in scope)
- purdue-l3-site-operations-brief.md — cross-vendor L3 reference (Camera Station/Device Manager analog: Windows-side fleet-management agents)

php2shell (CVE-2026-109618 / CVE-2026-109619) determination - 2026-10-22

php2shell context: this brief's PHP determination was driven by CVE-2026-109618 / CVE-2026-109619 ("php2shell", CVSS 9.2, PHP 5.4+, emergency-patched 2026-10-21). Those two IDs are carried here **as supplied by the requester** - they were not independently corroborated against NVD/MITRE in this pass, and no vendor-specific CVE was invented to pair with them.

Access re-verified, and the earlier gating finding in this brief still holds. The requester's premise that Axis firmware is "genuinely public, no login" does not survive testing. `axis.com/ftp/pub_soft/` is browsable (HTTP 200, 9,410 bytes) down through `/PACS/A1001/latest/`, but requesting the binary itself - `/ftp/pub_soft/PACS/A1001/latest/A1001.bin` - returns **HTTP 400** after redirecting to `https://auth.axis.com/authn/authentication/html`, delivering **6,476 bytes** of Curity-IdP login HTML. That is byte-for-byte the same result recorded earlier in this brief, independently reproduced. **Access verdict: GATED** (listing public, binary auth-walled).

The sidecars, however, are public - and they answer the question without the binary. All five fetched successfully (HTTP 200) and are saved to `firmware-staging/Axis/Access-Control/A1001-Network-Door-Controller/raw/`:

File	Bytes	Content
`ver.txt`	6	`1.65.6`
`A1001.bin.sha256`	65	`a0f52a89380912a68d8de92e18ed0ba2b5df4cb18ff5c37631099c8bd06a4e50`
`relnote.txt`	1,234	release notes
`howtoupgrade.txt`	7,220	upgrade procedure
`thirdpartysoftwarelicenses_A1001.txt`	**240,786**	full OSS component manifest

PHP finding: CONFIRMED ABSENT, from the vendor's own OSS manifest for A1001 firmware 1.65.6. `php` 0 hits, `PHP License` 0, `Zend` 0. The manifest is authoritative for what ships in the image.

What the web stack actually is: Apache httpd, evidenced by two declared Apache *modules* - `apache-authn-axisbasic 0.0.1` and `apache-pwauth 2.3.11` - not merely Apache-License boilerplate (the other 15 `apache` hits are LICENSE-2.0 text, checked in context). Also present: OpenSSL (20), Linux (4), BusyBox (1), Perl (3), Node (3), Lua (1). So Apache is there and *could* host a PHP module, but no PHP module is declared.

Verdict: A1001 at 1.65.6 is OUT OF SCOPE for php2shell. Caveats: the determination rests on the vendor manifest, not an extracted rootfs, because the binary is gated; and it covers A1001 only - the camera lines under `/pub_soft/MPQT/` were not checked. VT holds only a hash-only record for `a0f52a89…` (no file), so it cannot substitute for the binary either.

Extracted-firmware findings — AXIS OS 12.11.119.4 access controllers — 2026-10-22

This section supersedes the "no direct binary examination" limit stated in Scope above. The requester obtained the gated binaries and placed them in `firmware-staging/Axis/`. Five images were unpacked to a real rootfs and analysed directly, so the findings below rest on the shipped filesystem rather than on the vendor's OSS manifest.

Model	Release	Rootfs files	Product type
A1601	12.11.119.4	3,021	Network Door Controller
A1610	12.11.119.4	3,066	Network Door Controller
A1210	12.11.119.4	3,066	Network Door Controller
A1710	12.11.119.4	3,070	Network Door Controller
A1810	12.11.119.4	3,070	Network Door Controller

Platform: **AXIS OS 12.11.119.4**, `ID=axis`, built on **Yocto Poky "wrynose"**; userland is **ELF 32-bit LSB PIE, ARM EABI5 (armhf)**, `/usr/lib/ld-linux-armhf.so.3`, stripped.

Firmware container is signed, with a per-component digest manifest

`A1601.bin` (81,239,903 B) is **gzip**, decompressing to a container that unpacks into discrete component images plus signing metadata:

Artefact	Bytes	Role
`sign.bin`	328	detached signature, magic `pgnf`, carries the signing-domain string
`sums.bin`	448	7 components × (32-byte name + 32-byte digest)
`info.json`	—	release/product metadata
`boot.img`, `kernel.img`, `dtb.img`, `secmon.img`, `rootfs.img`	—	signed components

`info.json` declares `"SigningDomain": "axis-release-mx6sx"` — identical across all five models, and naming the **i.MX6 SoloX** SoC, so the signing domain is bound to the silicon rather than to the product. It also declares `"UpgradeableFrom": ["11.11", "12"]`, which bounds the downgrade path. `sums.bin` covers every component image, so a tampered `rootfs.img` fails the manifest before the signature is even considered. **Assessment: image-level tampering is not a realistic entry route on this platform.** Honest limit: this establishes that signing material *ships* and what it covers — it does **not** prove the bootloader enforces verification at runtime, which would need the boot ROM / `secmon` behaviour on real hardware. (`secmon.img` is a 64-byte stub in this package.)

No shipped default credentials — verified, all five models

`etc/shadow` holds **130 accounts and not one has a usable password hash**: `root:*`, every system and service account `!`. Checked mechanically on all five rootfs images — **0 unlocked accounts each**. The device is therefore in Axis's documented "set the admin password on first use" state, and there is **no vendor default to spray**. This is a materially stronger posture than most OT vendors in this corpus and should be recorded as such.

`sshd_config` sets `PermitRootLogin yes` with `AllowGroups root ssh-users` and hardens MACs (`MACs -*sha1,*sha1-*`). **`PermitRootLogin yes` is not exploitable on a shipped device** because `root` has no password — but it does mean that any process or operator that later sets a root password, or installs an `authorized_keys`, immediately gains remote root. Worth a config-audit check on deployed units rather than a firmware finding.

Web attack surface: Apache + 94 VAPIX CGIs, no PHP

Identical across all five models: **94 files under `axis-cgi`** (the VAPIX endpoints) and **53 Apache modules** (`mod_*.so`), including Axis-specific authN/authZ modules (`mod_authn_axisbasic`, `mod_authn_encodeduserfile`, `mod_authz_axisgroupfile`). The httpd runs as a dedicated `www` user, and the account table shows a **capability-split web user scheme** — `wwwa`, `wwwao`, `wwwaop`, `wwwaov`, `wwwaovp`, `wwwap`, `wwwav`, `wwwavp`, `wwwo`, `wwwop`, `wwwov`, `wwwovp`, `wwwp`, `wwwv`, `wwwvp`, `wwwanon` — i.e. one UID per admin/operator/viewer/PTZ privilege combination, so a CGI runs with only its tier's rights. That is a deliberate privilege-separation design and it meaningfully limits what a single compromised CGI yields.

The 94 CGIs remain the **primary remote attack surface** and are the right target for detection: in this corpus, access-control CGIs are what an attacker reaches first on a door controller.

php2shell — CONFIRMED ABSENT in the shipped rootfs

`find` for `*.php`, `libphp*` and `php-cgi` returns **0 hits on every one of the five rootfs images**. This upgrades the earlier A1001 determination from "*absent per the vendor OSS manifest*" to **absent in the shipped filesystem**, and extends it from one model to five.

Verdict: AXIS OS 12.11.119.4 access controllers are OUT OF SCOPE for php2shell (CVE-2026-109618 / CVE-2026-109619), on direct filesystem evidence. The web stack is Apache + CGI, not PHP. Scope limit: five access-control models at 12.11.119.4; the camera lines under `/pub_soft/MPQT/` were not acquired and are still undetermined.

VT behavioural differential — Axis corpus (2026-10-27)

Generated by `tools/Invoke-VendorDifferential.ps1` against the Axis known-good baseline (NSRL + local, platform-matched) and the VT malicious target set (7913 targets). Each behaviour is scored by how **rare** it is in this vendor's own known-good software: `rarity 100` = the baseline *never* exhibits it; a lower score = the baseline does, so it is scored down as benign-common.

> **Read this correctly.** The sparse OT baseline means the rarity-100 list is dominated by *generic* malicious behaviour, not Axis-specific indicators — any comparable malware trips most of it. The genuinely Axis-specific product of this differential is the **suppression list** at the end: behaviours this vendor's real software performs, which must **not** be alerted on when monitoring a host that runs it. Use the MITRE table as the TTP-tier hunting frame; use the suppression list to cut false positives.

> **Baseline plane.** The Axis known-good baseline is **embedded-Linux/ELF firmware with effectively no Windows binaries** (0 Windows API/registry/process/mutex behaviours suppressed). Every Windows-side behaviour is therefore `rarity 100` *by construction* and is **not** a meaningful discriminator — so the behavioural table below is drawn from the **ELF native-import plane**, which is the one that actually overlaps this baseline.

Category	Behaviours observed	Discriminating (rarity 100)	Benign-common (suppressed)
MITRE ATT&CK	852	852	0
Windows API	210	210	0
Process/cmdline	6164	6164	0
Registry	43285	43285	0
Mutex	1898	1898	0
YARA	1460	1456	4
Sigma	588	583	5
Certificate	4	3	1
Tags	263	224	39
ELF (native imports)	1186	676	510

Top discriminating MITRE ATT&CK techniques

Techniques present in the malicious corpus and **absent from the Axis known-good baseline**, ranked by how many malicious samples exhibit each.

Technique	Malicious samples	Last seen
T1082: Reads software policies	404	2026-02-04
T1082: Queries the volume information (name, serial number etc) of a device	350	2026-02-04
T1071: Adversaries may communicate using application layer protocols to avoid detection/network filtering by blending in with existing traffic.	348	2026-02-04

Technique	Malicious samples	Last seen
T1083: Reads ini files	321	2026-02-04
T1497: May sleep (evasive loops) to hinder dynamic analysis	319	2026-02-04
T1036: Creates files inside the user directory	289	2026-02-04
T1010: Sample monitors Window changes (e.g. starting applications), analyze the sample with the simulation cookbook	266	2026-02-04
T1518.001: May try to detect the virtual machine to hinder analysis (VM artifact strings found in memory)	266	2026-02-04
T1574.002: Tries to load missing DLLs	266	2026-02-04
T1497: Contains long sleeps (>= 3 min)	263	2026-02-04
T1082: An adversary may attempt to get detailed information about the operating system and hardware, including version, patches, hotfixes, service packs, and architecture.	247	2026-02-04
T1497: Contains medium sleeps (>= 30s)	238	2026-02-04

Highest-prevalence ELF native-import discriminators

Native imports/symbols present in the malicious ELF corpus and absent from Axis firmware, ranked by malicious prevalence. (Top entries are commonly libc/gcc runtime symbols — generic, as the note above warns.)

Symbol / import	Malicious samples
ELF!_Jv_RegisterClasses	260
ELF!__deregister_frame_info	135
ELF!__register_frame_info	132
ELF!__pthread_initialize_minimal	112
ELF!fprintf	60
ELF!htons	59
ELF!__lxstat64	49
ELF!atoi	48
ELF!fseeko	41
ELF!_gp_disp	32
ELF!__nptl_deallocate_tsd	29
ELF!__nptl_nthreads	29

Benign-common behaviours — suppress for this vendor (do NOT alert)

These appear in the Axis known-good baseline, so the differential scores them down and they should not drive alerts on a host running genuine Axis software. `base%` = share of the baseline exhibiting the behaviour. (550 suppressed in total; top 15 shown.)

Behaviour	Type	base%	rarity
No Sig	Certificate	100%	0
elf	Tags	36.9338%	63
arm	Tags	36.9338%	63

Behaviour	Type	base%	rarity
shared-lib	Tags	33.2946%	67
ELF!__aeabi_unwind_cpp_pr0	ELF (native imports)	31.3202%	69
ELF!**gmon_start**	ELF (native imports)	27.4874%	73
ELF!_ITM_deregisterTMCloneTable	ELF (native imports)	26.597%	73
ELF!_ITM_registerTMCloneTable	ELF (native imports)	23.887%	76
ELF!__stack_chk_guard	ELF (native imports)	22.7255%	77
ELF!__aeabi_unwind_cpp_pr1	ELF (native imports)	20.0542%	80
ELF!__stack_chk_fail	ELF (native imports)	19.4348%	81
json	Tags	19.2412%	81
ELF!__cxa_finalize	ELF (native imports)	18.6992%	81
ELF!memset	ELF (native imports)	15.2923%	85
ini	Tags	14.6729%	85